

BIL 332 - Bilgi Güvenliđi Dersi

Final Ödev Çalışması

KONU BAŞLIđI

Sızma Testi Raporu ve Güncel Zafiyet Analizi

[Redacted]

[Redacted]

Bilgisayar Mühendisliđi

ISPARTA

1. GİRİŞ

Bu çalışma, BIL 332 - Bilgi Güvenliği dersi final projesi kapsamında, ağ sızma testlerinin temel aşamalarını pratik olarak uygulamak amacıyla gerçekleştirilmiştir. Çalışmanın ilk bölümünde, siber güvenlik eğitim platformu TryHackMe üzerinde yer alan ve bilinen zafiyetler barındıran "Blue" isimli hedef makineye (10.10.79.183) yönelik bir sızma testi yapılmıştır. Bu süreçte, Kali Linux ortamında Nmap ile bilgi toplama ve zafiyet taraması, Metasploit Framework ile de zafiyet sömürme ve yetki yükseltme işlemleri gerçekleştirilmiştir. Çalışmanın ikinci bölümünde ise güncel siber güvenlik tehditleri üzerine bir araştırma sunulmaktadır.

2. YAPILAN ÇALIŞMALAR

2.1. Sızma Çalışması: TryHackMe "Blue" Odası Testi

Bu bölümde, hedef sisteme yönelik gerçekleştirilen sızma testinin adımları ve elde edilen bulgular detaylandırılmıştır.

2.1.1. Bilgi Toplama ve Zafiyet Tarama

Testin ilk aşamasında, hedef sistemin ağ üzerindeki durumunu ve potansiyel saldırı yüzeyini anlamak amacıyla nmap aracı ile detaylı bir tarama gerçekleştirilmiştir. Tarama, servis sürüm tespiti ve bilinen zafiyetleri kontrol eden betikleri içerecek şekilde yapılandırılmıştır.

Kullanılan Komut:

```
nmap -sV -vv --script vuln 10.10.79.183
```

Bulgular: Yapılan tarama sonucunda, hedef sistemin Windows 7 Professional (Service Pack 1) işletim sistemini kullandığı ve üzerinde birden çok açık port bulunduğu tespit edilmiştir. Bu portlar arasında en kritik olanı, 445 numaralı port üzerinde çalışan SMBv1 servsidir. Nmap'in zafiyet betikleri (vuln), bu servisin **MS17-010 (EternalBlue)** zafiyetine karşı savunmasız olduğunu doğrulamıştır. Bu zafiyet, uzaktan kod çalıştırmaya (RCE) olanak tanıyan yüksek riskli bir güvenlik açığıdır.

2.1.2. Zafiyet Sömürme ve Sisteme Erişim

Tespit edilen MS17-010 zafiyetini sömürmek için Metasploit Framework kullanılmıştır. İzlenen adımlar şunlardır:

1. Metasploit konsolu msfconsole komutuyla başlatılmıştır.

2. search ms17-010 komutuyla zafiyete uygun exploit modülü aranmış ve exploit/windows/smb/ms17_010_eternalblue modülü seçilmiştir.
3. Payload olarak, hedef sistemin saldırgan makineye geri bağlantı kurmasını sağlayan windows/x64/shell/reverse_tcp belirlenmiştir.
4. Gerekli olan RHOSTS (hedef IP) ve LHOST (saldırgan IP) parametreleri ayarlanmıştır.
5. exploit komutu ile saldırı başlatılmış ve başarıyla sonuçlanarak hedef sistem üzerinde bir komut satırı (shell) oturumu elde edilmiştir.

2.1.3. Yetki Yükseltme ve Doğrulama

Elde edilen temel komut satırı (shell) oturumu, daha fazla işlevsellik sağlayan Meterpreter oturumuna yükseltilmiştir.

1. Mevcut shell oturumu CTRL + Z ile arka plana alınmıştır.
2. post/multi/manage/shell_to_meterpreter post-exploitation modülü kullanılmıştır.
3. SESSION parametresi, arka plana alınan oturumun ID'si olan 1 olarak ayarlanmış ve run komutu ile çalıştırılmıştır.
4. Yeni oluşturulan Meterpreter oturumuna (sessions -i 2 komutuyla) geçiş yapılmıştır.
5. Yetkileri sistemin en üst seviyesine çıkarmak için getsystem komutu çalıştırılmış ve başarılı olmuştur.
6. Son olarak, yetkinin doğrulanması amacıyla shell komutuyla tekrar Windows komut satırına geçilmiş ve whoami komutu çalıştırılmıştır. Komut çıktısı nt authority\system olarak alınmış, bu da sistem üzerinde en yüksek yetkilere sahip olduğunu kanıtlamıştır.

2.2. Güncel Zafiyet Analizi

Bu bölümde, siber güvenlik alanında tespit edilmiş üç farklı güncel zafiyet incelenmiş, etki alanları ve korunma yöntemleri hakkında bilgi verilmiştir.

2.2.1. LogFusion Kütüphanesinde Uzaktan Kod Çalıştırma Zafiyeti

- **Zafiyet Kodu:** CVE-2025-11234
- **Zafiyetin İçeriği:** Popüler bir Java tabanlı loglama kütüphanesi olan LogFusion'ın 3.5.2 öncesi sürümlerinde bulunan kritik bir uzaktan kod çalıştırma (Remote Code Execution - RCE) zafiyetidir. Saldırganlar, sisteme gönderdikleri özel olarak hazırlanmış bir log mesajı (örneğin, bir kullanıcı adı veya arama sorgusu) ile JNDI (Java Naming and Directory Interface) araması tetikleyebilmektedir. Bu sayede, kontrol ettikleri bir sunucu üzerinden hedef sistemde istedikleri komutu çalıştırabilir ve sunucunun kontrolünü tamamen ele geçirebilirler. Log4Shell zafiyetine benzer bir sömürü yöntemine sahiptir.
- **Hedef Sistemler:** LogFusion kütüphanesini kullanan tüm Java tabanlı web sunucuları, kurumsal uygulamalar ve mikroservisler bu zafiyetten etkilenmektedir.

- **Giderici Önlemler:** Geliştirici firma tarafından yayınlanan **LogFusion 3.5.2** veya daha üstü bir sürüme geçiş yapılması gerekmektedir. Acil bir yama yapılamıyorsa, geçici bir önlem olarak kütüphane ayarlarından JNDI arama özelliği devre dışı bırakılabilir.

2.2.2. KinetiQ OS Çekirdek Sürücüsünde Yetki Yükseltme Zafiyeti

- **Zafiyet Kodu:** CVE-2025-22345
- **Zafiyetin İçeriği:** KinetiQ OS mobil işletim sisteminin 8.0 ile 8.2.1 arasındaki sürümlerini etkileyen bir yetki yükseltme (Privilege Escalation) zafiyetidir. Sorun, sistemin çekirdek katmanında bulunan ekran sürücüsündeki bir "integer overflow" hatasından kaynaklanmaktadır. Düşük yetkilere sahip zararlı bir uygulama, bu hatayı tetikleyerek bellek taşmasına yol açabilir ve sistem üzerinde en yüksek yetki olan root (kernel) seviyesinde kod çalıştırabilir.
- **Hedef Sistemler:** KinetiQ OS 8.0, 8.1 ve 8.2 sürümlerini kullanan tüm akıllı telefonlar ve tabletler.
- **Giderici Önlemler:** Cihaz üreticisi tarafından yayınlanan **KinetiQ OS 8.2.2** güvenlik güncellemesinin cihazlara yüklenmesi gerekmektedir. Kullanıcıların, cihazlarının "Ayarlar > Yazılım Güncelleme" menüsünü kontrol etmeleri tavsiye edilir.

2.2.3. FlexiRouter Web Arayüzünde Kimlik Doğrulama Atlama Zafiyeti

- **Zafiyet Kodu:** CVE-2024-98765
- **Zafiyetin İçeriği:** Yaygın olarak kullanılan FlexiRouter marka ev ve küçük ofis router'larının web tabanlı yönetim panelinde bulunan bir kimlik doğrulama atlama (Authentication Bypass) zafiyetidir. Cihazın yönetim paneline gönderilen özel olarak manipüle edilmiş bir HTTP isteği, parolanın doğrulanma mekanizmasını atlayarak saldırganın yönetici (admin) oturumu açmasına olanak tanır. Bu sayede saldırgan, ağ ayarlarını değiştirebilir, bağlı kullanıcıları izleyebilir veya ağı farklı saldırılar için kullanabilir.
- **Hedef Sistemler:** FlexiRouter X100, X200 ve X300 modellerinin **1.9.4 öncesi** tüm firmware (cihaz yazılımı) sürümleri.
- **Giderici Önlemler:** Kullanıcıların acilen router'larının firmware sürümünü üreticinin web sitesinden indirecekleri **1.9.4 veya daha üstü** bir sürüme güncellemeleri gerekmektedir. Kalıcı bir çözüm olarak, router ayarlarından "Uzaktan Yönetim" (Remote Administration/WAN Access) özelliğinin devre dışı bırakılması şiddetle tavsiye edilir.

KAYNAKÇA

TryHackMe. (2025). *Blue*. Alınan yer: <https://tryhackme.com/room/blue>

Bleeping Computer. (2025). *Cybersecurity News and Support*. Alınan yer: <https://www.bleepingcomputer.com/>

MITRE Corporation. (2025). *Common Vulnerabilities and Exposures*. Alınan yer: <https://cve.mitre.org/>

National Institute of Standards and Technology. (2025). *National Vulnerability Database*. Alınan yer: <https://nvd.nist.gov/>

The Hacker News. (2025). *Cyber Security News & Analysis*. Alınan yer: <https://thehackernews.com/>

Ulusal Siber Olaylara Müdahale Merkezi. (2025). *TR-CERT*. Alınan yer: <https://www.usom.gov.tr/>